ĐẠI HỌC CÔNG NGHIỆP HÀ NỘI

TRƯỜNG CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

======*======**



BÁO CÁO TIỂU LUẬN THUỘC HỌC PHẦN: ĐẢM BẢO CHẤT LƯỢNG PHẦN MỀM

ĐỀ TÀI: ĐẢM BẢO CHẤT LƯỢNG CHO DỰ ÁN ỨNG DỤNG WEB QUẢN LÝ DỰ ÁN VIRA

GVHD: **ThS.Vũ Đình Minh**

Lớp - Nhóm: **20261IT6085001- Nhóm 5**

Thành viên: **Trần Đức Ngọc - 2023602056**

Hà Nội, 10/2026

LỜI MỞ ĐẦU

Chất lượng phần mềm chịu ảnh hưởng bởi cách tổ chức mã nguồn, mức độ tuân thủ quy ước lập trình, khả năng bảo trì và việc kiểm soát quyền truy cập. Rà soát mã nguồn giúp phát hiện những điểm chưa phù hợp với yêu cầu và tiêu chuẩn của dự án, qua đó hỗ trợ hạn chế lỗi và tạo thuận lợi cho việc sửa đổi phần mềm.

Vira là ứng dụng web hỗ trợ quản lý dự án và cộng tác công việc theo cấu trúc Workspace – Project – Task/Subtask. Hệ thống cung cấp các chức năng như Kanban, Sprint, phân công công việc và quản lý quyền thành viên. Vì vậy, hoạt động rà soát mã nguồn cần chú ý đến khả năng bảo trì và việc kiểm tra quyền tại backend.

Trong khuôn khổ bài kiểm tra thường xuyên 2 của học phần Đảm bảo chất lượng phần mềm, báo cáo cá nhân này tập trung thiết lập và vận dụng hoạt động SQA cho Vira. Báo cáo lựa chọn Waterfall làm mô hình tham chiếu để bố trí hoạt động kiểm soát theo giai đoạn và ISO/IEC 25010 làm cơ sở lựa chọn đặc tính chất lượng phù hợp với nhiệm vụ. [1].

Nội dung báo cáo gồm lựa chọn mô hình và tiêu chuẩn chất lượng; thiết lập bộ tiêu chuẩn tài liệu SQA; xây dựng quy trình rà soát mã nguồn; và áp dụng checklist vào phạm vi mã nguồn được xem xét. Kết quả được trình bày kèm căn cứ và vị trí minh chứng. Phần rà soát mã nguồn trong tài liệu này là rà soát tĩnh; báo cáo phân biệt rõ bằng chứng trong mã nguồn với các kiểm thử chưa được thực thi trong phạm vi lập báo cáo.

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Ý nghĩa
API	Giao diện lập trình ứng dụng (Application Programming Interface)
DTO	Đối tượng truyền dữ liệu (Data Transfer Object)
HTTP	Giao thức truyền tải siêu văn bản (Hypertext Transfer Protocol)
ISO/IEC	Tổ chức Tiêu chuẩn hóa Quốc tế / Ủy ban Kỹ thuật Điện Quốc
JWT	Mã thông báo web JSON (JSON Web Token)
SQA	Đảm bảo chất lượng phần mềm (Software Quality Assurance)
UI	Giao diện người dùng (User Interface)

MỤC LỤC

PHẦN 1. LỰA CHỌN MÔ HÌNH PHÁT TRIỂN VÀ TIÊU CHUẨN CHẤT LƯỢNG.....
1.2. Mô hình phát triển được lựa chọn.....
1.2.1. Mô hình Waterfall.....
1.2.2. Căn cứ lựa chọn Waterfall cho nhiệm vụ cá nhân.....
1.2.3. Vị trí và quan hệ của hoạt động rà soát.....
1.3. Tiêu chuẩn/mô hình chất lượng được lựa chọn.....
1.3.1. ISO/IEC 25010.....
1.3.2. Các đặc tính áp dụng vào rà soát mã nguồn.....
1.3.3. Chuyển mô hình thành tiêu chí có thể kiểm tra.....
PHẦN 2. THIẾT LẬP BỘ TIÊU CHUẨN TÀI LIỆU SQA CHO DỰ ÁN.....
2.1. Mục đích và phạm vi áp dụng.....
2.2. Cấu trúc chung của tài liệu SQA.....
2.3. Quy tắc mã và tên tài liệu.....
2.5. Người soạn, người rà soát và người phê duyệt.....
2.6. Nội dung, trình bày và bảo mật.....
2.7. Lưu trữ, truy vết và sử dụng tài liệu.....
2.8. Kết luận phần 2.....
PHẦN 3. QUY TRÌNH SQA PHỤC VỤ RÀ SOÁT MÃ NGUỒN.....
3.1. Mục tiêu.....
3.2. Phạm vi.....
3.3. Vai trò và trách nhiệm.....
3.4. Đầu vào.....
3.5.1. Bước 1 - Khởi tạo và xác định phạm vi.....
3.5.2. Bước 2 - Chuẩn bị tiêu chí và tài liệu.....
3.5.3. Bước 3 - Rà soát mã nguồn.....
3.5.4. Bước 4 - Ghi nhận và phân loại phát hiện.....

3.5.5. Bước 5 - Trao đổi và xử lý phát hiện.....
3.5.6. Bước 6 - Rà soát lại.....
3.5.7. Bước 7 - Tổng hợp và kết thúc.....
3.6. Đầu ra.....
3.7. Điều kiện chấp nhận và tiêu chí kết thúc.....
3.8. Minh chứng và kiểm soát hồ sơ.....
3.9. Hạn chế của rà soát cá nhân và biện pháp kiểm soát.....
3.10. Kết luận phần 3.....
PHẦN 4. CHECKLIST RÀ SOÁT MÃ NGUỒN VÀ KẾT QUẢ ÁP DỤNG.....
KẾT LUẬN.....
TÀI LIỆU THAM KHẢO.....

PHẦN 1. LỰA CHỌN MÔ HÌNH PHÁT TRIỂN VÀ TIÊU CHUẨN CHẤT LƯỢNG

1.1. Phạm vi và mục tiêu lựa chọn

Vira là ứng dụng web hỗ trợ quản lý dự án và cộng tác công việc theo cấu trúc Workspace – Project – Task/Subtask. Hệ thống hỗ trợ quản lý công việc theo Kanban, Backlog và Sprint; quản lý thành viên; phân công công việc; bình luận; đính kèm tệp; thông báo và kiểm soát quyền truy cập. Giao diện được xây dựng bằng React và Vite, backend sử dụng Java và Spring Boot, dữ liệu được lưu trữ bằng MySQL [4], [5].

Trong phạm vi cá nhân, mục tiêu là xây dựng cách rà soát mã nguồn có căn cứ, tiêu chí và hồ sơ để kiểm tra phần mã nguồn được giao. Báo cáo ưu tiên các nội dung nêu trong đề bài: tuân thủ coding standards, khả năng bảo trì và phân quyền. Tùy phạm vi mã nguồn được giao, việc rà soát có thể xem xét thêm tính phù hợp của logic chức năng, tính toàn vẹn dữ liệu và các quy tắc kỹ thuật như optimistic locking. Kết luận chỉ áp dụng cho module, file và phiên bản mã nguồn thực tế được kiểm tra.

1.2. Mô hình phát triển được lựa chọn

1.2.1. Mô hình Waterfall

Waterfall (mô hình thác nước) tổ chức hoạt động phát triển theo các giai đoạn tuần tự. Trình tự thường gặp gồm phân tích yêu cầu, thiết kế, lập trình, kiểm thử, triển khai và bảo trì. Đầu ra của một giai đoạn là cơ sở để thực hiện và đánh giá giai đoạn tiếp theo. Theo tài liệu môn học, mô hình này phù hợp hơn với dự án có yêu cầu tương đối rõ ràng và ít thay đổi .

1.2.2. Căn cứ lựa chọn Waterfall cho nhiệm vụ cá nhân

Waterfall được lựa chọn làm mô hình tham chiếu cho hoạt động SQA cá nhân vì giúp xác định thời điểm rà soát và đầu ra cần có. Trong phạm vi báo cáo, điểm rà soát mã nguồn được đặt sau khi phần mã thuộc phạm vi đã được lập trình và trước khi chuyển sang hoạt động kiểm thử tương ứng. Tại điểm rà soát, người thực hiện đối chiếu mã nguồn với yêu cầu chức năng, quy tắc nghiệp vụ, quy ước lập trình và quy định phân quyền có liên quan.

Waterfall giúp tổ chức hoạt động thành trình tự rõ ràng: xác định phạm vi; chuẩn bị căn cứ và tài liệu đầu vào; rà soát theo tiêu chí; ghi nhận phát hiện; trao đổi và xử lý; kiểm tra lại; tổng hợp kết quả. Mỗi bước tạo ra hồ sơ có thể truy vết, phù hợp với yêu cầu thiết lập bộ tiêu chuẩn tài liệu, thủ tục SQA và báo cáo kết quả.

Trong báo cáo này, Waterfall là cơ sở tổ chức hoạt động SQA cá nhân, không phải kết luận rằng toàn bộ Vira đã được phát triển theo mô hình này. Các chức năng như Kanban và Sprint là tính năng của sản phẩm, không tự xác định mô hình phát triển phần mềm. Nếu quy trình thực tế của dự án có tính lặp hoặc áp dụng Agile, thủ tục rà soát vẫn có thể dùng cho từng phạm vi hoặc phiên bản; thời điểm rà soát cần điều chỉnh theo cách làm thực tế. Khi yêu cầu thay đổi, căn cứ rà soát và tài liệu liên quan cần được cập nhật trước khi đánh giá lại.

1.2.3. Vị trí và quan hệ của hoạt động rà soát

Rà soát mã nguồn là hoạt động xem xét tĩnh sản phẩm công việc nhằm phát hiện sai lệch so với yêu cầu, quy tắc và tiêu chuẩn đã xác định. Hoạt động này thường được thực hiện sau lập trình và trước kiểm thử, hoặc lặp lại khi có thay đổi đáng kể. Rà soát hỗ trợ nhưng không thay thế kiểm thử: rà soát xem xét mã nguồn và tài liệu; kiểm thử thực thi phần mềm để đánh giá hành vi trong tình huống cụ thể. Vì vậy, kết luận từ rà soát tĩnh phải giới hạn trong bằng chứng đã xem xét; nhận định về hành vi khi chạy cần được bổ sung bằng kiểm thử phù hợp.

1.3. Tiêu chuẩn/mô hình chất lượng được lựa chọn

1.3.1. ISO/IEC 25010

ISO/IEC 25010 được sử dụng trong báo cáo làm mô hình tham chiếu để xác định những khía cạnh chất lượng cần quan tâm khi rà soát mã nguồn Vira. Theo tài liệu học phần, mô hình chất lượng sản phẩm của phiên bản ISO/IEC 25010:2011 gồm tám đặc tính: tính phù hợp chức năng, hiệu suất, tính tương thích, khả năng sử dụng, độ tin cậy, bảo mật, khả năng bảo trì và khả chuyển [2]. Mỗi đặc tính phản ánh một góc độ khác nhau của chất lượng phần mềm. Chẳng hạn, tính phù hợp chức năng xem xét mức độ đáp ứng yêu cầu; độ tin cậy liên quan đến khả năng hoạt động ổn định; bảo mật xem xét việc bảo vệ hệ

thống và dữ liệu; còn khả năng bảo trì quan tâm đến mức độ dễ hiểu, phân tích và sửa đổi mã nguồn.

Trong phạm vi nhiệm vụ cá nhân, báo cáo ưu tiên khả năng bảo trì vì đề bài yêu cầu xem xét việc tuân thủ quy ước lập trình và tính dễ bảo trì; bảo mật vì Vira có phân quyền theo Workspace và Project; và tính phù hợp chức năng để đối chiếu logic xử lý với yêu cầu, quy tắc nghiệp vụ. Độ tin cậy được xem xét ở phạm vi hẹp khi các thao tác trên task thuộc phạm vi rà soát liên quan đến version và optimistic locking. Các đặc tính còn lại chỉ được đưa vào khi có liên quan trực tiếp đến mã nguồn và nhiệm vụ được giao.

ISO/IEC 25010 cung cấp mô hình để định hướng lựa chọn tiêu chí, chứ không tự tạo ra kết luận Đạt/Không đạt cho từng đoạn code. Vì vậy, mỗi đặc tính được áp dụng cần được chuyển thành câu hỏi kiểm tra cụ thể, phương pháp đánh giá và yêu cầu minh chứng. Báo cáo chỉ đánh giá các tiêu chí và phần mã nguồn đã thực sự xem xét; không xem đây là đánh giá toàn diện mọi đặc tính chất lượng, cũng không tuyên bố dự án Vira đã được chứng nhận phù hợp với ISO/IEC 25010.

1.3.2. Các đặc tính áp dụng vào rà soát mã nguồn

- Khả năng bảo trì (Maintainability): Đặc tính này được ưu tiên vì nhiệm vụ cá nhân yêu cầu xem xét việc tuân thủ coding standards và khả năng bảo trì mã nguồn. Rà soát tập trung vào cách tổ chức package, module và lớp; mức độ rõ ràng, nhất quán của tên gọi; sự phân chia trách nhiệm giữa controller, service và các thành phần khác; mức độ phức tạp hoặc lặp lại của logic; và khả năng lần theo luồng xử lý từ API đến nơi thực hiện nghiệp vụ. Người rà soát cũng xem xét liệu mã nguồn có dễ phân tích, sửa đổi, mở rộng và kiểm thử hay không. Khi phát hiện vấn đề, cần ghi rõ vị trí, ảnh hưởng đến việc hiểu hoặc sửa mã và hướng xử lý đề xuất. Các tiêu chí này tham khảo những khía cạnh của khả năng bảo trì như tính module, khả năng phân tích, sửa đổi và kiểm thử trong tài liệu môn học.
- Bảo mật (Security): Đặc tính này được lựa chọn vì Vira có cơ chế phân quyền ở cấp Workspace và Project, đồng thời một số thao tác trên task, thành viên và dữ liệu liên quan bị giới hạn theo vai trò. Rà soát tập trung vào việc xác định endpoint

nào cần xác thực; thao tác nào cần quyền đặc biệt; backend kiểm tra quyền ở đâu; và dữ liệu được truy vấn hoặc trả về có giới hạn đúng theo Workspace, Project và người dùng hay không. Cần lần theo luồng từ endpoint/controller đến service hoặc vị trí áp dụng chính sách quyền, đồng thời xem xét cả thao tác đọc và thay đổi dữ liệu. Việc chỉ ẩn nút trên giao diện không đủ để kết luận API đã được bảo vệ. Nếu tài liệu dự án chưa nêu rõ chính sách cho một tình huống, cần ghi nhận để xác nhận thay vì tự suy đoán quyền mong muốn.

- Tính phù hợp chức năng (Functional suitability): Đặc tính này được dùng để đối chiếu logic trong mã nguồn với yêu cầu chức năng và quy tắc nghiệp vụ của Vira. Người rà soát cần xác định yêu cầu hoặc quy tắc làm căn cứ, tìm vị trí mã nguồn xử lý, rồi xem các điều kiện, đầu vào và kết quả xử lý có phù hợp hay không. Nội dung rà soát có thể bao gồm việc hệ thống có từ chối dữ liệu không hợp lệ, xử lý đúng trạng thái và áp dụng đúng quy tắc nghiệp vụ trong phạm vi được giao hay không. Kết luận cần phân biệt điều có thể xác nhận qua việc đọc mã với hành vi chỉ có thể xác nhận khi chạy. Nếu cần khẳng định hệ thống phản hồi đúng trong tình huống cụ thể, cần bổ sung kiểm thử phù hợp và ghi nhận kết quả thực thi riêng.
- Độ tin cậy (Reliability): Đặc tính này chỉ được xem xét khi liên quan trực tiếp đến module hoặc thao tác nằm trong phạm vi rà soát; kết quả không được khái quát thành đánh giá độ tin cậy của toàn hệ thống. Với các thao tác trên task thuộc phạm vi, cần kiểm tra quy định gửi version hiện tại để hỗ trợ optimistic locking, đặc biệt đối với thao tác cập nhật trạng thái, di chuyển, xóa mềm hoặc khôi phục. Người rà soát lần theo luồng từ request DTO qua controller đến service để xác định version có được yêu cầu, truyền và kiểm tra khi cập nhật hay không. Cũng cần xem xét cách hệ thống xử lý version bị thiếu hoặc đã cũ, và cách phản hồi khi xảy ra xung đột dữ liệu. Nếu chỉ thấy trường version trong DTO hoặc annotation trên entity thì chưa đủ để kết luận toàn bộ luồng xử lý đúng; khi cần xác nhận hành vi lúc chạy, phải bổ sung kiểm thử phù hợp.

1.3.3. Chuyển mô hình thành tiêu chí có thể kiểm tra

ISO/IEC 25010 cung cấp các đặc tính chất lượng ở mức mô hình. Để áp dụng vào nhiệm vụ cá nhân, đặc tính được lựa chọn cần chuyển thành câu hỏi kiểm tra, phương pháp đánh giá và yêu cầu minh chứng. Bảng dưới đây định hướng việc lập checklist; trạng thái chỉ được ghi sau khi kiểm tra thực tế.

Bảng 1.1. Chuyển đặc tính chất lượng thành định hướng rà soát mã nguồn

Đặc tính chất lượng	**Câu hỏi rà soát gợi ý**	**Phương pháp và minh chứng**
Khả năng bảo trì	Tên lớp, phương thức và biến có phản ánh đúng trách nhiệm không? Một lớp/phương thức có đảm nhiệm quá nhiều trách nhiệm không?	Đọc mã nguồn; ghi đường dẫn file, tên lớp/phương thức, vị trí và nhận xét.
Bảo mật	Endpoint hoặc thao tác nhạy cảm có kiểm tra xác thực và quyền ở backend không? Dữ liệu có giới hạn theo Workspace/Project không?	Lần theo luồng controller–service; đối chiếu quy tắc phân quyền; ghi vị trí kiểm tra quyền và truy vấn dữ liệu.
Tính phù hợp chức năng	Logic xử lý có đáp ứng yêu cầu hoặc quy tắc nghiệp vụ được dùng làm căn cứ không?	Đối chiếu yêu cầu với đoạn mã liên quan; ghi mã yêu cầu/tên tài liệu và vị trí code.
Độ tin cậy	Với thao tác thuộc phạm vi, version có được yêu cầu và xử lý phù hợp không?	Lần theo request, controller và service; ghi vị trí nhận, kiểm tra và cập nhật version.

Waterfall được chọn làm mô hình tham chiếu để xác định vị trí, đầu vào và đầu ra của hoạt động rà soát mã nguồn cá nhân; lựa chọn này không khẳng định toàn dự án Vira áp dụng Waterfall. ISO/IEC 25010 được dùng làm căn cứ hình thành tiêu chí,

tập trung vào khả năng bảo trì, bảo mật và tính phù hợp chức năng; độ tin cậy được xem xét khi liên quan trực tiếp đến thao tác thuộc phạm vi. Mỗi tiêu chí cần gắn với phương pháp và minh chứng. Đây là cơ sở cho bộ tiêu chuẩn tài liệu và quy trình ở các phần tiếp theo.

PHẦN 2. THIẾT LẬP BỘ TIÊU CHUẨN TÀI LIỆU SQA CHO DỰ ÁN

2.1. Mục đích và phạm vi áp dụng

Bộ tiêu chuẩn tài liệu SQA được xây dựng nhằm thống nhất cách lập và quản lý hồ sơ rà soát mã nguồn cá nhân cho Vira. Cách trình bày có tham khảo template SQA tiếng Anh nhưng được điều chỉnh theo quy mô, vai trò và phạm vi thực tế của dự án, không sao chép nguyên cơ chế quản trị tổ chức lớn [3].

Việc áp dụng thống nhất các quy tắc này giúp người thực hiện và người xem xét nhận biết được mục đích, phạm vi và tình trạng của từng tài liệu; xác định tài liệu nào đang được sử dụng; và theo dõi những thay đổi đã thực hiện. Đồng thời, bộ tiêu chuẩn hỗ trợ liên kết các tài liệu với nhau, từ kế hoạch và căn cứ rà soát đến checklist, phát hiện, hướng xử lý và báo cáo kết quả. Nhờ đó, hồ sơ SQA có thể phản ánh rõ mã nguồn, chức năng và phiên bản thực tế đã được xem xét, hạn chế nhầm lẫn giữa đề xuất, quan sát và kết quả đã xác minh.

Bộ tiêu chuẩn áp dụng cho các tài liệu cá nhân phục vụ rà soát mã nguồn Vira, bao gồm:

- Kế hoạch và phiếu xác định phạm vi rà soát: ghi mục tiêu, module/chức năng, danh sách tệp, phiên bản mã nguồn, căn cứ và nội dung loại trừ.
- Quy ước và tiêu chí chất lượng: nêu các quy tắc lập trình, yêu cầu phân quyền và tiêu chí dùng để đánh giá mã nguồn.
- Quy trình rà soát mã nguồn: quy định vai trò, đầu vào, trình tự thực hiện, đầu ra và điều kiện kết thúc.
- Checklist rà soát: ghi mã tiêu chí, nội dung kiểm tra, cách đánh giá, kết quả, minh chứng và hướng xử lý nếu không đạt.
- Phiếu theo dõi phát hiện: ghi vấn đề, căn cứ, ảnh hưởng, mức độ, hướng xử lý, trạng thái và kết quả rà soát lại.
- Báo cáo kết quả: tổng hợp phạm vi, phương pháp, kết quả đánh giá, phát hiện còn mở và giới hạn của lần rà soát.

Phạm vi của bộ tiêu chuẩn này giới hạn ở việc quản lý tài liệu phục vụ nhiệm vụ SQA cá nhân; không thay thế quy định quản lý tài liệu chính thức của dự án hoặc của học phần. Các mã tài liệu, mẫu và quy tắc trình bày trong báo cáo là đề xuất để áp dụng cho nhiệm vụ cá nhân, không được xem là quy định chính thức của Vira nếu chưa được người có thẩm quyền phê duyệt.

2.2. Cấu trúc chung của tài liệu SQA

Mỗi tài liệu SQA cần được trình bày thống nhất, dễ đọc và thuận tiện cho việc tra cứu, cập nhật. Cấu trúc chung gồm các nội dung sau:

- Thông tin kiểm soát: mã và tên tài liệu, phiên bản, ngày lập hoặc cập nhật, người soạn, người rà soát, người phê duyệt (nếu có) và trạng thái tài liệu.
- Mục đích: nêu lý do lập tài liệu và hoạt động tài liệu hỗ trợ.
- Phạm vi áp dụng: xác định dự án, module, chức năng hoặc lần rà soát liên quan.
- Thuật ngữ và tài liệu tham chiếu: giải thích các thuật ngữ cần thiết và liệt kê đề bài, quy định, tiêu chuẩn hoặc tài liệu dự án được sử dụng làm căn cứ.
- Nội dung chính: trình bày tiêu chuẩn, quy trình, tiêu chí, kết quả hoặc hướng dẫn phù hợp với loại tài liệu.
- Lịch sử thay đổi: ghi phiên bản, ngày cập nhật, nội dung thay đổi và người thực hiện.

Đối với checklist và phiếu phát hiện, cần bổ sung:

- Mã lần rà soát, thời gian thực hiện và người thực hiện.
- Module hoặc chức năng được kiểm tra và phiên bản mã nguồn làm căn cứ.
- Kết quả đánh giá, mã phát hiện nếu có, cùng minh chứng tương ứng như đường dẫn tệp, tên lớp/hàm hoặc số dòng.
- Hướng xử lý và kết quả rà soát lại đối với tiêu chí không đạt.

Trạng thái tài liệu gồm Bản nháp, Chờ rà soát, Đã phê duyệt và Hết hiệu lực. Chỉ ghi Đã phê duyệt khi có xác nhận thực tế; nếu chưa có người phê duyệt chính thức, cần ghi rõ tình trạng thay vì tự xác nhận.

2.3. Quy tắc mã và tên tài liệu

Mã tài liệu sử dụng cấu trúc VIRA-SQA-[LOẠI]-[SỐ THỨ TỰ]. VIRA nhận diện dự án; SQA nhận diện nhóm tài liệu đảm bảo chất lượng; LOẠI mô tả loại tài liệu; SỐ THỨ TỰ là hai chữ số tăng dần. Tên file gồm mã tài liệu, tên rút gọn, phiên bản và ngày cập nhật; không sử dụng tên chung chung hoặc khó phân biệt.

Danh mục hồ sơ đề xuất gồm: VIRA-SQA-PLN-01 (kế hoạch SQA cá nhân); VIRA-SQA-STD-01 (quy ước rà soát mã nguồn); VIRA-SQA-PROC-01 (quy trình rà soát); VIRA-SQA-CHK-01 (checklist); VIRA-SQA-LOG-01 (phiếu theo dõi phát hiện); và VIRA-SQA-RPT-01 (báo cáo kết quả). Bảng 2.1 mô tả nội dung chính của từng hồ sơ.

Bảng 2.1. Danh mục hồ sơ SQA cá nhân

Mã loại	**Tên hồ sơ**	**Nội dung chính**
PLN	Kế hoạch SQA cá nhân	Mục tiêu, phạm vi, tiêu chí và cách lưu hồ sơ.
STD	Quy ước rà soát mã nguồn	Coding standards và căn cứ chất lượng áp dụng.
PROC	Quy trình rà soát	Vai trò, đầu vào, trình tự và điều kiện kết thúc.
CHK	Checklist	Tiêu chí, cách đánh giá, trạng thái và minh chứng.
LOG	Phiếu theo dõi phát hiện	Mô tả vấn đề, mức độ, người xử lý và trạng thái.
RPT	Báo cáo kết quả	Phạm vi, phương pháp, thống kê, kết luận và giới hạn.

Tên file sử dụng mẫu : VIRA-SQA-[LOẠI]-[SCOPE]_v[MAJOR.MINOR]_[YYYYMMDD].docx. SCOPE là module, chức năng hoặc phạm vi; phiên bản thể hiện lần ban hành/cập nhật; ngày dùng dạng năm-tháng-ngày. Ví dụ: VIRA-SQA-CHK-TASK_v1.0_20261028.docx. Nếu tài liệu lưu trong hệ thống quản lý phiên bản, tên file vẫn cần đủ rõ để nhận diện khi tải riêng.

Phiên bản 1.0 là bản đầu tiên được xác lập làm cơ sở sử dụng. Tăng số MINOR, ví dụ 1.1, khi sửa trình bày hoặc bổ sung giải thích mà không đổi phạm vi/tiêu chí cốt lõi. Tăng số MAJOR, ví dụ 2.0, khi thay đổi đáng kể phạm vi, trách nhiệm, quy trình hoặc tiêu chí. Mọi thay đổi phải cập nhật lịch sử phiên bản. Bản cũ được lưu riêng hoặc giữ lịch sử; không ghi đè làm mất khả năng truy vết.

2.5. Người soạn, người rà soát và người phê duyệt

Để xác định rõ trách nhiệm trong quá trình lập và sử dụng tài liệu SQA, cần phân biệt các vai trò sau:

- Người soạn: là cá nhân trực tiếp lập tài liệu và chịu trách nhiệm về tính đầy đủ, chính xác, nhất quán của nội dung. Người soạn xác định phạm vi áp dụng, tập hợp căn cứ và minh chứng, trình bày kết quả, cập nhật tài liệu khi có thay đổi và ghi nhận lịch sử phiên bản.
- Người rà soát tài liệu: kiểm tra tài liệu có đáp ứng mục đích và phạm vi đã nêu hay không; thông tin, thuật ngữ và cách trình bày có nhất quán không; kết luận có căn cứ và truy vết được đến minh chứng không. Người rà soát cũng chỉ ra nội dung còn thiếu, chưa rõ hoặc cần chỉnh sửa trước khi tài liệu được sử dụng.
- Người phê duyệt: xác nhận tài liệu đủ điều kiện sử dụng theo quy định của học phần hoặc dự án. Người phê duyệt cần có thẩm quyền phù hợp với cơ chế áp dụng; việc phê duyệt chỉ được ghi nhận khi đã có xác nhận thực tế.
- Trạng thái xác nhận: việc nêu các vai trò trên trong tài liệu không có nghĩa là hoạt động rà soát hoặc phê duyệt đã diễn ra. Nếu chưa có người rà soát hoặc phê duyệt, cần ghi rõ “Chưa thực hiện” hoặc “Không áp dụng”; không ghi tên người hoặc trạng thái giả định.

Trong hoạt động rà soát mã nguồn, cần phân biệt các vai trò nghiệp vụ:

- Người thực hiện SQA: áp dụng quy trình và checklist, kiểm tra mã nguồn trong phạm vi được giao, ghi nhận kết quả và lập phiếu phát hiện kèm minh chứng.
- Tác giả hoặc người phụ trách mã nguồn: tiếp nhận phát hiện, phân tích nguyên nhân, thực hiện sửa đổi hoặc giải thích trường hợp không áp dụng; đồng thời cung cấp thông tin về thay đổi đã thực hiện.
- Người rà soát lại: kiểm tra phần mã nguồn sau khi xử lý để xác định phát hiện đã được khắc phục hay chưa, rồi cập nhật trạng thái và minh chứng.

Một người có thể đảm nhiệm nhiều vai trò trong nhiệm vụ cá nhân, nhưng cần ghi rõ vai trò thực tế ở từng hoạt động. Nếu không có người độc lập rà soát lại, báo cáo cần nêu giới hạn về tính độc lập và lưu bằng chứng cho việc tự kiểm tra.

2.6. Nội dung, trình bày và bảo mật

- Ngôn ngữ: Phần thuyết minh sử dụng tiếng Việt. Tên công nghệ, thuật ngữ kỹ thuật, tên module, lớp, hàm, biến và đường dẫn mã nguồn được giữ nguyên khi cần bảo đảm chính xác.
- Thuật ngữ: Giải thích thuật ngữ hoặc chữ viết tắt ở lần xuất hiện đầu tiên nếu có thể gây nhầm lẫn; sau đó sử dụng thống nhất trong toàn bộ báo cáo.
- Bảng, hình và checklist: Đánh số thứ tự, đặt tên ngắn gọn và dẫn chiếu trong nội dung. Nếu sử dụng thông tin hoặc hình ảnh từ nguồn bên ngoài dự án, cần ghi rõ nguồn tham khảo.
- Cách trình bày nhận định: Phân biệt rõ nội dung nào là quy định chính thức, đề xuất của người thực hiện, quan sát khi rà soát hay kết quả đã được xác minh. Không trình bày nhận định chưa có đủ căn cứ như một kết luận chắc chắn.
- Mô tả phát hiện: Nêu rõ vấn đề, vị trí mã nguồn liên quan, tiêu chí hoặc căn cứ đối chiếu, ảnh hưởng có thể xảy ra và hướng xử lý đề xuất.

- Bảo mật thông tin: Không đưa mật khẩu, token, khóa bí mật, thông tin đăng nhập hoặc dữ liệu cá nhân vào báo cáo. Trước khi đính kèm ảnh chụp, log hoặc đoạn mã làm minh chứng, cần che hoặc loại bỏ thông tin nhạy cảm.

2.7. Lưu trữ, truy vết và sử dụng tài liệu

- Lưu trữ: Lưu tài liệu trong thư mục riêng của báo cáo cá nhân hoặc tại vị trí do học phần quy định. Tên tệp cần thể hiện nội dung và phiên bản để thuận tiện tra cứu.
- Liên kết giữa các hồ sơ: Kế hoạch SQA xác định phạm vi rà soát; tiêu chuẩn và quy ước cung cấp căn cứ; quy trình hướng dẫn các bước thực hiện; checklist ghi kết quả theo từng tiêu chí; phiếu phát hiện theo dõi vấn đề và hướng xử lý; báo cáo tổng hợp kết quả.
- Truy vết phát hiện: Mỗi phát hiện cần liên kết với mã tiêu chí, module hoặc chức năng, đường dẫn tệp và vị trí mã nguồn nếu xác định được. Đồng thời, ghi phiên bản hoặc mốc mã nguồn được kiểm tra và trạng thái xử lý của phát hiện.
- Cập nhật hồ sơ: Khi phạm vi, mã nguồn hoặc kết quả rà soát thay đổi, người soạn cập nhật tài liệu liên quan, tăng phiên bản khi cần và ghi lại nội dung thay đổi để tránh sử dụng nhầm bản cũ.
- Kiểm tra trước khi sử dụng hoặc nộp: Đối chiếu mã tài liệu, phiên bản, ngày lập/cập nhật, tài liệu tham chiếu, bảng biểu và các liên kết giữa checklist, phiếu phát hiện và báo cáo. Bảo đảm kết luận trong báo cáo phù hợp với kết quả và minh chứng đã ghi nhận.
- Trạng thái duyệt: Tài liệu chưa được giảng viên hoặc người hướng dẫn xác nhận phải ghi đúng trạng thái hiện tại, chẳng hạn “Chờ rà soát” hoặc “Chưa được phê duyệt”; chỉ chuyển sang “Đã phê duyệt” khi có xác nhận thực tế.

2.8. Kết luận phần 2

Bộ tiêu chuẩn xác định cấu trúc, cách đặt mã và tên, quản lý phiên bản, vai trò soạn/rà soát/phê duyệt, trạng thái tài liệu và danh mục hồ sơ cần dùng cho nhiệm vụ

cá nhân. Liên kết mã và phiên bản giữa các hồ sơ hỗ trợ truy vết từ yêu cầu chất lượng đến tiêu chí, phát hiện, xử lý và kết luận. Đây là quy ước đề xuất và cần điều chỉnh nếu học phần hoặc dự án có quy định chính thức khác.

PHẦN 3. QUY TRÌNH SQA PHỤC VỤ RÀ SOÁT MÃ NGUỒN

3.1. Mục tiêu

Quy trình này được xây dựng để hướng dẫn và kiểm soát có hệ thống hoạt động rà soát mã nguồn trong nhiệm vụ SQA cá nhân đối với dự án Vira. Việc áp dụng quy trình giúp hoạt động kiểm tra được thực hiện theo phạm vi, căn cứ và cách ghi nhận thống nhất, thay vì chỉ dựa trên nhận xét chủ quan.

Cụ thể, quy trình hướng đến các mục tiêu sau:

- Xác định căn cứ đánh giá: Đối chiếu mã nguồn với yêu cầu của đề tài, quy định của dự án và tiêu chí chất lượng đã lựa chọn.
- Phát hiện sai lệch: Nhận diện những điểm chưa phù hợp với coding standards, khả năng bảo trì, phân quyền và các yêu cầu kỹ thuật liên quan trong phạm vi rà soát.
- Ghi nhận kết quả có thể kiểm chứng: Mỗi nhận định cần gắn với tiêu chí, vị trí mã nguồn và minh chứng phù hợp.
- Theo dõi việc xử lý: Ghi nhận hướng khắc phục, người phụ trách và kết quả rà soát lại đối với các phát hiện cần xử lý.
- Đưa ra kết luận đúng phạm vi: Kết luận chỉ phản ánh phần mã nguồn và phiên bản đã kiểm tra; không khái quát thành đánh giá toàn bộ hệ thống nếu phạm vi thực tế không bao gồm toàn bộ hệ thống.

Trọng tâm rà soát của nhiệm vụ là tuân thủ quy ước mã nguồn, khả năng bảo trì và kiểm soát phân quyền. Tính phù hợp chức năng, toàn vẹn dữ liệu hoặc các quy tắc kỹ thuật khác được xem xét khi có liên quan trực tiếp đến chức năng và phạm vi được giao.

Theo nội dung SQA trong tài liệu môn học, hoạt động chất lượng dựa trên quy trình, tiêu chuẩn, checklist và hồ sơ. Trong đó, rà soát mã nguồn là hoạt động kiểm soát sản phẩm nhằm phát hiện vấn đề trong mã nguồn; còn việc thiết lập, áp dụng và

duy trì quy trình là hoạt động đảm bảo chất lượng. Vì vậy, quy trình này vừa hướng dẫn cách rà soát, vừa quy định cách ghi nhận kết quả và minh chứng.

3.2. Phạm vi

Quy trình áp dụng cho hoạt động rà soát các tệp mã nguồn và chức năng thuộc nhiệm vụ cá nhân trong dự án Vira. Phạm vi cụ thể cần được xác định và ghi nhận trước mỗi lần rà soát để người thực hiện và người đọc kết quả biết chính xác phần nào đã được kiểm tra.Thông tin phạm vi cần ghi gồm:

- Module hoặc chức năng: khu vực nghiệp vụ được rà soát, ví dụ xác thực, quản lý task hoặc quản lý thành viên.
- Danh sách tệp liên quan: đường dẫn các tệp mã nguồn được kiểm tra; có thể bổ sung tên lớp, hàm, API hoặc thành phần giao diện liên quan.
- Mốc mã nguồn: nhánh, commit, phiên bản phát hành hoặc mốc mã nguồn khác đủ rõ để xác định nội dung đã rà soát.
- Yêu cầu và tiêu chí áp dụng: yêu cầu nghiệp vụ, quy định dự án, coding standards hoặc tiêu chí trong checklist dùng làm căn cứ đánh giá.
- Nội dung loại trừ: các tệp, chức năng hoặc loại kiểm tra không thuộc phạm vi; nếu không có thì ghi rõ.

Với nội dung phân quyền, ưu tiên kiểm tra điểm xác thực quyền ở backend đối với các thao tác nhạy cảm thuộc phạm vi. Việc giao diện ẩn nút hoặc thành phần không được xem là đủ căn cứ để kết luận API đã kiểm soát quyền; cần truy vết đến điểm xử lý phía máy chủ và đối chiếu với vai trò, phạm vi dữ liệu liên quan.

Với nội dung khả năng bảo trì, xem xét cấu trúc module, cách đặt tên, mức độ phân chia trách nhiệm giữa lớp và hàm, khả năng theo dõi luồng xử lý và mức độ thuận lợi khi thay đổi mã nguồn trong module được chọn.

Nếu người giao nhiệm vụ chỉ định module hoặc chức năng cụ thể, phạm vi đó được ưu tiên. Nếu chưa có chỉ định, người thực hiện lựa chọn phạm vi phù hợp với thời gian và khả năng kiểm tra, sau đó ghi vào phiếu rà soát trước khi bắt đầu. Quy

trình không mặc định kết quả cho bất kỳ module nào và không đại diện cho đánh giá toàn bộ Vira nếu chưa có hoạt động rà soát tương ứng.

3.3. Vai trò và trách nhiệm

Do đây là tiểu luận cá nhân, người thực hiện chịu trách nhiệm chính về hoạt động SQA. Các vai trò tác giả code, reviewer và người hướng dẫn được nêu để phân định trách nhiệm; tên cá nhân và trạng thái phê duyệt chỉ ghi khi có dữ liệu thực tế.

Trong hồ sơ, người thực hiện SQA/reviewer chịu trách nhiệm xác định phạm vi, chuẩn bị căn cứ, đánh giá theo checklist và lập kết luận. Tác giả hoặc người phụ trách mã nguồn giải thích thiết kế, tiếp nhận và xử lý phát hiện theo phân công. Người hướng dẫn/phê duyệt xem xét khi học phần yêu cầu; không ghi trạng thái đã phê duyệt nếu chưa có xác nhận thực tế. Người rà soát lại xác minh việc khắc phục; nếu cá nhân tự rà soát lại, hồ sơ phải nêu rõ giới hạn về tính độc lập.

3.4. Đầu vào

Trước khi rà soát, người thực hiện chuẩn bị các đầu vào sau:

- Phạm vi module/chức năng và danh sách file cần rà soát.
- Mã nguồn tại nhánh, commit hoặc phiên bản có thể nhận diện.
- Yêu cầu chức năng, quy tắc nghiệp vụ và tài liệu thiết kế liên quan nếu có.
- Coding standards, quy định bảo mật và quy tắc phân quyền của dự án.
- Tiêu chí ánh xạ từ ISO/IEC 25010 và checklist đúng phiên bản.
- Phiếu ghi kết quả, mẫu phát hiện và công cụ đọc/tìm kiếm code nếu có sử dụng.

Nếu tài liệu đầu vào không tồn tại hoặc không thể truy cập, người thực hiện ghi nhận thiếu hụt. Trạng thái có thể là “Chưa đủ thông tin”; không chuyển thành Đạt dựa trên suy đoán.

Luồng quy trình tổng quát: Khởi tạo và xác định phạm vi → Chuẩn bị tiêu chí và tài liệu → Rà soát mã nguồn → Ghi nhận và phân loại phát hiện → Trao đổi và xử lý → Rà soát lại → Tổng hợp và kết thúc. Hồ sơ của từng bước được nêu tại các mục dưới đây.

3.5.1. Bước 1 - Khởi tạo và xác định phạm vi

Trước khi tiến hành rà soát, người thực hiện tạo mã nhận diện cho lần rà soát để phân biệt hồ sơ này với các lần rà soát khác.. Hồ sơ cần ghi ngày thực hiện, người rà soát, dự án, module hoặc chức năng được chọn và lý do lựa chọn phạm vi.

Phạm vi rà soát cần xác định cụ thể các tệp mã nguồn, lớp, phương thức hoặc endpoint liên quan. Đối với mỗi tệp, cần ghi đường dẫn tương đối trong dự án để người khác có thể tìm lại. Nếu một tiêu chí liên quan đến nhiều thành phần, chẳng hạn kiểm tra quyền từ API đến service, phạm vi cần bao gồm các thành phần cần thiết để lần theo luồng xử lý đó.

Sau khi xác định phạm vi, người thực hiện xem xét các rủi ro trọng tâm của module được chọn. Với nhiệm vụ rà soát mã nguồn Vira, cần ưu tiên khả năng truy cập trái quyền, sai lệch dữ liệu, vi phạm quy tắc nghiệp vụ và các vấn đề làm giảm khả năng bảo trì. Phạm vi cần đủ cụ thể để từng tiêu chí có thể được kiểm tra, có căn cứ đối chiếu và gắn với minh chứng xác định.

3.5.2. Bước 2 - Chuẩn bị tiêu chí và tài liệu

Thu thập yêu cầu, quy tắc dự án và quy ước mã nguồn; chọn checklist đúng phiên bản. Mỗi tiêu chí cần thể hiện nội dung kiểm tra, căn cứ, phương pháp đánh giá và loại minh chứng cần lưu. Tiêu chí không áp dụng được đánh dấu Không áp dụng và giải thích; tiêu chí thiếu căn cứ có thể ghi Chưa đủ thông tin. Hồ sơ tạo ra: danh sách tài liệu đầu vào và checklist được lựa chọn.

3.5.3. Bước 3 - Rà soát mã nguồn

Đối chiếu mã nguồn với từng tiêu chí: cách đặt tên và cấu trúc; trách nhiệm lớp/hàm; khả năng truy vết luồng xử lý; kiểm tra xác thực và phân quyền ở backend; sự phù hợp với quy tắc nghiệp vụ; và quy tắc kỹ thuật như optimistic locking khi thuộc phạm vi. Với quyền truy cập, lần theo luồng từ endpoint tới service hoặc nơi thực thi chính sách quyền, không chỉ quan sát trạng thái giao diện.

Rà soát tập trung vào phát hiện có thể mô tả và tái kiểm tra. Nếu sửa ngay có thể làm mất dấu trạng thái ban đầu, cần ghi nhận phát hiện và minh chứng trước; sau đó mới xử lý theo phân công và quy trình quản lý thay đổi của dự án. Hồ sơ tạo ra: checklist có trạng thái, nhận xét và vị trí minh chứng.

3.5.4. Bước 4 - Ghi nhận và phân loại phát hiện

Mỗi phát hiện được cấp mã duy nhất và ghi tiêu chí liên quan, mô tả, file/vị trí, căn cứ đối chiếu, ảnh hưởng hoặc rủi ro, mức độ, hướng xử lý, người phụ trách và trạng thái. Minh chứng có thể là đường dẫn file, tên lớp/phương thức, số dòng, commit hoặc ảnh/log đã loại dữ liệu nhạy cảm.

Thang mức độ được đề xuất thống nhất như sau: Nghiêm trọng khi có khả năng gây truy cập trái phép, sai lệch dữ liệu lớn hoặc hỏng chức năng trọng yếu; Cao khi ảnh hưởng đáng kể tới chức năng, quy tắc nghiệp vụ hoặc toàn vẹn dữ liệu; Trung bình khi làm giảm khả năng bảo trì, gây sai lệch một phần hoặc tăng rủi ro lỗi; Thấp khi là vấn đề nhỏ về tính nhất quán/khả năng đọc, chưa có ảnh hưởng trực tiếp đáng kể. Mức độ cần gắn với ảnh hưởng cụ thể và không được xem là phân loại chính thức của ISO/IEC 25010.

Đây là thang phân loại đề xuất cho nhiệm vụ cá nhân, không phải mức phân loại được khẳng định là quy định chính thức của ISO/IEC 25010. Người rà soát cần nêu lý do khi phân loại.

3.5.5. Bước 5 - Trao đổi và xử lý phát hiện

Phát hiện được chuyển cho người phụ trách mã nguồn hoặc người giao nhiệm vụ theo cơ chế thực tế. Phản hồi được ghi nhận theo trạng thái: chấp nhận, cần làm rõ, không chấp nhận kèm lý do hoặc hoãn xử lý có nêu rủi ro. Nếu cá nhân trực tiếp sửa code, cần ghi nhận thay đổi và phân biệt trạng thái trước/sau sửa. Việc phát hiện đã được trao đổi không đồng nghĩa với việc đã khắc phục. Hồ sơ tạo ra: phiếu theo dõi phát hiện được cập nhật phản hồi và người phụ trách.

3.5.6. Bước 6 - Rà soát lại

Sau khi có thay đổi, kiểm tra lại đúng tiêu chí và phạm vi bị ảnh hưởng. Cập nhật trạng thái thành Đã khắc phục, Chưa khắc phục, Hoãn xử lý/Chấp nhận rủi ro hoặc Đóng không sửa theo quyết định thực tế. Không đóng phát hiện chỉ dựa trên thông báo đã sửa; cần có bằng chứng rà soát lại. Hồ sơ tạo ra: phiếu phát hiện được cập nhật kết quả xác minh.

3.5.7. Bước 7 - Tổng hợp và kết thúc

Tổng hợp số tiêu chí Đạt, Không đạt, Không áp dụng và Chưa đủ thông tin; số phát hiện theo mức độ và trạng thái; phát hiện còn mở; và giới hạn của lần rà soát.

Báo cáo kết luận nêu phạm vi, phiên bản mã nguồn, checklist và thời điểm sử dụng. Hồ sơ được lưu theo tiêu chuẩn tài liệu tại Phần 2. Hồ sơ tạo ra: báo cáo kết quả rà soát mã nguồn.

3.6. Đầu ra

Đầu ra bắt buộc của mỗi lượt gồm phiếu phạm vi (người thực hiện, module/file, phiên bản code và yêu cầu liên quan); checklist hoàn thành (mã tiêu chí, trạng thái, minh chứng và nhận xét); danh sách phát hiện (mã, mức độ, vị trí, căn cứ, hướng xử lý, trạng thái và kết quả rà soát lại); báo cáo kết quả (phương pháp, phạm vi, thống kê, kết luận và giới hạn); cùng liên kết commit hoặc hồ sơ thay đổi nếu có sửa mã nguồn. Hồ sơ chỉ phản ánh kết quả đã thực hiện, không ghi giả định thành minh chứng.

3.7. Điều kiện chấp nhận và tiêu chí kết thúc

Một lần rà soát hoàn tất về mặt hồ sơ khi phạm vi và phiên bản code được xác định; mọi tiêu chí áp dụng có trạng thái; mỗi mục Không đạt có mô tả và minh chứng; mỗi mục Không áp dụng hoặc Chưa đủ thông tin có lý do; phát hiện có trạng thái xử lý; và kết luận giới hạn trong bằng chứng đã thu thập.

Việc hoàn tất hồ sơ khác với việc đề xuất chuyển mã nguồn sang kiểm thử. Để đề xuất chuyển phần code đã rà soát sang kiểm thử, không còn phát hiện Nghiêm trọng chưa xử lý trong phạm vi; phát hiện Cao được xử lý hoặc có quyết định chấp nhận rủi ro được ghi nhận; phát hiện còn lại có người phụ trách hoặc kế hoạch xử lý. Đây là điều kiện đề xuất cho báo cáo cá nhân và cần điều chỉnh nếu dự án hoặc giảng viên quy định ngưỡng khác. Kết quả không đồng nghĩa với nghiệm thu toàn bộ sản phẩm.

3.8. Minh chứng và kiểm soát hồ sơ

Minh chứng phải đủ để người khác kiểm tra lại kết luận. Hồ sơ ghi ít nhất mã và ngày rà soát; người thực hiện; phạm vi; nhánh/commit hoặc phiên bản; mã và phiên bản checklist; tiêu chí; kết quả; vị trí file/code; phát hiện; hướng xử lý; trạng thái rà soát lại. Ảnh chỉ dùng bổ trợ, không thay thông tin đường dẫn và vị trí truy vết. Dữ liệu nhạy cảm phải được che hoặc loại bỏ.

3.9. Hạn chế của rà soát cá nhân và biện pháp kiểm soát

Rà soát do một cá nhân thực hiện có hạn chế về tính độc lập và nguy cơ bỏ sót do quen thuộc với mã nguồn hoặc diễn giải chủ quan. Để giảm rủi ro, người thực hiện dùng checklist đã xác định trước, đối chiếu từng tiêu chí với căn cứ, lưu vị trí minh chứng và đọc lại phát hiện trước khi kết luận. Nếu điều kiện học phần cho phép, nên đề nghị người hướng dẫn hoặc người khác xem xét các phát hiện có ảnh hưởng lớn đến bảo mật, phân quyền hoặc toàn vẹn dữ liệu. Báo cáo cần nêu giới hạn này, không trình bày kết quả như một cuộc kiểm toán độc lập.

3.10. Kết luận phần 3

Quy trình xác định mục tiêu, phạm vi, vai trò, đầu vào, trình tự thực hiện, đầu ra, điều kiện kết thúc và cách lưu minh chứng cho hoạt động rà soát mã nguồn cá nhân. Bảy bước giúp liên kết phạm vi với tiêu chí, phát hiện, xử lý và báo cáo kết quả. Quy trình là cơ sở để áp dụng checklist ở phần tiếp theo; kết luận chỉ được đưa ra sau khi có minh chứng thực tế và phải giới hạn trong phạm vi mã nguồn, phiên bản cùng tiêu chí đã kiểm tra.

PHẦN 4. CHECKLIST RÀ SOÁT MÃ NGUỒN VÀ KẾT QUẢ ÁP DỤNG

4.1. Phạm vi, phương pháp và checklist rà soát

- Hoạt động rà soát trong phần này được thực hiện đối với mã nguồn backend của dự án Vira, tập trung vào quản lý thành viên Project, phân quyền Project và Workspace.
- Kết quả được giới hạn trong phạm vi các tệp, luồng xử lý và vị trí minh chứng được ghi trong checklist. Đây là hoạt động rà soát tĩnh, không thay thế kiểm thử phần mềm. Trong phạm vi lập báo cáo, người thực hiện không chạy unit test, integration test, E2E, penetration test hoặc xác minh trên môi trường triển khai. Vì vậy, các nhận xét về rủi ro dựa trên mã nguồn và tài liệu đối chiếu, chưa được xác nhận bằng kiểm thử khi chạy chương trình.
- Checklist được xây dựng từ các tiêu chí về coding standards và khả năng bảo trì, phân quyền và bảo mật, tính đúng đắn và toàn vẹn dữ liệu. Mỗi tiêu chí có mã nhận diện, nội dung kiểm tra, cách đánh giá, kết quả và minh chứng trong mã nguồn. Đối với tiêu chí không đạt, checklist ghi nhận mức độ và hướng xử lý đề xuất. Các vấn đề cần tiếp tục theo dõi được liên kết với mã phát hiện trong phiếu theo dõi.
- Kết quả đánh giá được phân thành bốn trạng thái: Đạt khi bằng chứng trong phạm vi rà soát cho thấy tiêu chí được đáp ứng; Không đạt khi có căn cứ cho thấy tiêu chí chưa được đáp ứng hoặc tồn tại rủi ro cần xử lý; Không áp dụng khi tiêu chí không thuộc phạm vi rà soát và có ghi rõ lý do; Chưa đủ thông tin khi chưa có đủ căn cứ để kết luận. Trạng thái "Chưa đủ thông tin" không được tính là Đạt hoặc Không đạt cho đến khi được xác minh.

4.2. Kết quả rà soát và xử lý phát hiện

- Trong 25 tiêu chí đã áp dụng theo kết quả được ghi trong hồ sơ checklist, có 23 tiêu chí Đạt, 2 tiêu chí Không đạt và không có tiêu chí Không áp dụng. Hai tiêu chí Không đạt là M02 về tên phương thức chưa phản ánh chính xác hành vi và S10 về phạm vi quyền xem danh sách Project đã lưu trữ. Các kết quả này phản ánh rà soát tĩnh các luồng được nêu trong checklist, không đại diện cho toàn bộ endpoint hoặc module backend. Hồ

sơ checklist hiện ghi nhận working tree làm mốc mã nguồn, nhưng chưa ghi commit cụ thể hoặc ngày rà soát chính xác; vì vậy, các kết quả cần được xác nhận lại trên commit được chỉ định trước khi dùng làm kết luận chính thức.

- F-01 - Tên phương thức chưa phản ánh hành vi (mức Thấp). Phương thức requireTaskCreator trong TaskAuthorizationService.java kiểm tra người dùng có phải là thành viên của Project hay không; phương thức được gọi khi tạo task tại TaskService.java. Tên hiện tại có thể khiến người bảo trì hiểu rằng hàm kiểm tra người dùng có phải tác giả của task, trong khi điều kiện thực tế chỉ xác nhận membership. Có thể đổi tên thành requireTaskCreationPermission hoặc tên tương đương sau khi đối chiếu với chính sách tạo task của Vira.
- F-02 - Rủi ro về quyền xem Project đã lưu trữ (mức Cao, cần xác nhận chính sách). Trong ProjectService.java, luồng lấy danh sách Project đang hoạt động có lọc theo quyền truy cập, trong khi findArchivedByWorkspace chỉ kiểm tra người gọi là thành viên Workspace rồi truy vấn các Project đã lưu trữ thuộc Workspace đó. Nếu chính sách yêu cầu thành viên Project mới được xem dự án, cách xử lý hiện tại có thể làm lộ thông tin dự án lưu trữ cho thành viên Workspace không thuộc Project. Cần xác nhận chính sách với người phụ trách; sau đó giới hạn truy vấn theo quyền thành viên Project hoặc ghi rõ ngoại lệ vào đặc tả và bổ sung kiểm tra quyền phù hợp. [5].
- Hai phát hiện F-01 và F-02 đang ở trạng thái mở trong phiếu theo dõi của workbook checklist. Tại thời điểm lập báo cáo, chưa có người xử lý hoặc ngày mục tiêu được xác nhận. Với F-01, sau khi đổi tên phương thức cần rà soát các điểm gọi và xác nhận quy tắc tạo task. Với F-02, cần chốt chính sách xem Project đã lưu trữ trước khi sửa mã nguồn hoặc đặc tả. Sau khi xử lý, kiểm tra lại theo chính sách đã xác nhận và lưu minh chứng; chỉ đóng phát hiện khi có bằng chứng rà soát lại.

- Ngoài 25 tiêu chí đã áp dụng, workbook checklist đề xuất thêm 25 tiêu chí mở rộng liên quan đến cấu trúc trách nhiệm, kiểm soát truy cập đối tượng, dữ liệu tệp đính kèm, transaction và các trường do server quản lý. Các tiêu chí này chưa được đánh giá và không được cộng vào kết quả 23 Đạt, 2 Không đạt.
- Checklist chi tiết, phiếu theo dõi hai phát hiện và 25 tiêu chí mở rộng chưa đánh giá được cung cấp trong workbook "VIRA_Checklist_RaSoat_MaNguon_DayDu.xlsx" đính kèm báo cáo. Workbook này là tài liệu kết quả đi kèm; các tiêu chí bổ sung vẫn để trống cho đến khi có lần rà soát và minh chứng tương ứng [6].

KẾT LUẬN

Báo cáo đã xây dựng căn cứ lựa chọn Waterfall và ISO/IEC 25010, thiết lập bộ tiêu chuẩn tài liệu SQA, mô tả quy trình rà soát mã nguồn và áp dụng checklist vào một phạm vi cụ thể của backend Vira. Các phần này liên kết mục tiêu chất lượng với quy tắc dự án, tiêu chí kiểm tra, hồ sơ kết quả và cách theo dõi phát hiện.

Qua rà soát tĩnh, các luồng được kiểm tra có những cơ chế bảo vệ đáng chú ý như xác thực mặc định, kiểm tra thành viên và vai trò ở service, giới hạn thao tác chủ sở hữu, kiểm tra version và xử lý lỗi tập trung. Báo cáo đồng thời ghi nhận hai điểm cần xử lý: tên một phương thức chưa phản ánh rõ hành vi và chính sách xem Project đã lưu trữ chưa nhất quán giữa các danh sách. Kết luận này giới hạn ở mã nguồn được rà soát và không thay thế kiểm thử động hoặc đánh giá độc lập.

TÀI LIỆU THAM KHẢO

[1] Tài liệu đề bài cá nhân, “Bài kiểm tra thường xuyên 2 - Đảm bảo chất lượng phần mềm”, học phần Đảm bảo chất lượng phần mềm, mã đề TX2-10_11_12-045, 2026.

[2] ISO/IEC, ISO/IEC 25010:2011, Systems and software engineering - Systems and software Quality Requirements and Evaluation (SQuaRE) - System and software quality models, 2011.

[3] Systems Engineering Process Office, Space and Naval Warfare Systems Center San Diego, Software Quality Assurance Plan Template, TM-SQA-01, Version 2.0, 16 December 2003.

[4] Dự án Vira, AGENTS.md, “Development Conventions” và “Project Structure”, tài liệu nội bộ của dự án, truy cập ngày 02/11/2026.

[5] Dự án Vira, DAC_TA_VIRA.md, đặc tả yêu cầu và phân quyền, tài liệu nội bộ của dự án, truy cập ngày 02/11/2026.

[6] Trần Đức Ngọc, VIRA_Checklist_RaSoat_MaNguon_DayDu.xlsx, workbook checklist rà soát mã nguồn và phiếu phát hiện đính kèm báo cáo, 2026.